

CYBERSECURITY RISK MANAGEMENT POLICY

Table of Contents

Table of Contents.....	1
1. Purpose	2
2. Scope	2
3. Policy Objectives.....	2
4. Roles and Responsibilities	2
5. Risk Identification Requirements.....	2
6. Risk Assessment Requirements	3
7. Risk Appetite and Tolerance	3
8. Risk Treatment	3
9. Risk Acceptance and Approval Authority.....	3
10. Remediation and Escalation.....	3
11. Continuous Monitoring and Reassessment	3
12. Risk Reporting and Metrics.....	4
13. Policy Exceptions	4
14. Compliance and Enforcement.....	4
15. Policy Review and Maintenance	4
16. Related Frameworks and Supporting Artifacts	4
17. Version History	5

1. Purpose

This policy establishes the requirements for identifying, assessing, documenting, treating, accepting, monitoring, escalating, and reporting cybersecurity risk across the organization. It provides a consistent approach for managing cybersecurity risk and supports risk-informed business decisions aligned with organizational objectives and approved risk tolerance.

2. Scope

This policy applies to cybersecurity risk arising from:

- Information systems, applications, cloud environments, infrastructure, and technology services
- Identity and access management, privileged access, and security architecture
- Third-party and supplier relationships
- Sensitive, regulated, and business-critical data
- Vulnerabilities, security incidents, audit and compliance findings, and policy exceptions
- Material technology, architecture, product, or business changes

3. Policy Objectives

- Establish consistent governance and accountability for cybersecurity risk.
- Standardize risk identification, assessment, scoring, treatment, acceptance, and monitoring.
- Maintain a centralized enterprise cyber risk register as the authoritative record for managed cybersecurity risks.
- Escalate risks that exceed established appetite or tolerance to the appropriate decision authority.
- Provide leadership with timely, decision-useful visibility into cybersecurity risk exposure and remediation performance.

4. Roles and Responsibilities

Role	Responsibility
Executive Leadership	Provides oversight, establishes risk direction, and makes or delegates risk decisions within approved authority.
Cybersecurity / GRC	Maintains the cyber risk program, methodology, risk register, governance artifacts, monitoring, escalation, and reporting.
Risk Owner	Owns the business risk, reviews assessment results, selects treatment, and accepts residual risk within delegated authority.
Remediation Owner	Implements corrective actions and provides status and evidence of remediation.
Control Owner	Maintains assigned controls and supports assessment of control design and operating effectiveness.
Business / System Owner	Provides business, system, data, dependency, and impact context needed for risk assessment.

Detailed accountability is maintained in the Cyber Risk Governance RACI.

5. Risk Identification Requirements

Cybersecurity risks shall be identified through relevant risk sources, including vulnerability management, cloud and IAM reviews, third-party assessments, audits, compliance reviews, incidents, policy exceptions, security testing, and significant technology or business changes.

Findings meeting established intake criteria shall be evaluated and, when appropriate, documented in the Enterprise Cyber Risk Register.

6. Risk Assessment Requirements

Cybersecurity risks shall be assessed using the approved enterprise cyber risk methodology. Assessments shall consider:

- Likelihood
- Business and security impact
- Inherent risk
- Existing controls and compensating controls
- Control effectiveness
- Residual risk

Risk ratings shall follow the approved likelihood, impact, and scoring methodology. Assessments shall contain sufficient rationale to support the assigned ratings and resulting risk decision.

7. Risk Appetite and Tolerance

Cybersecurity risks shall be evaluated against established risk appetite and tolerance criteria. Risks within tolerance may be managed through normal operating processes. Risks exceeding approved tolerance shall require treatment, escalation, or formal acceptance by the appropriate authority.

8. Risk Treatment

Risk Owners shall select and document an appropriate risk treatment strategy:

- Mitigate - reduce likelihood and/or impact through corrective actions or additional controls.
- Accept - formally acknowledge residual risk within authorized decision authority.
- Avoid - discontinue or change the activity creating the risk.
- Transfer - allocate defined risk exposure through contractual, insurance, or other approved mechanisms.

Mitigation plans shall identify accountable remediation owners, corrective actions, target dates, dependencies, and measurable completion criteria.

9. Risk Acceptance and Approval Authority

Risk acceptance shall be formally documented and approved at the level of authority established by the Risk Appetite and Tolerance Criteria. The individual implementing a control or remediation action shall not independently approve acceptance of the resulting residual risk unless explicitly authorized by governance.

Each risk acceptance shall document:

- Business justification
- Residual risk rating
- Relevant compensating controls
- Approver and approval date
- Expiration or mandatory review date

Risk acceptance is time-bound and shall be reassessed before expiration or when material conditions change.

10. Remediation and Escalation

Risk remediation activities shall be tracked against established target dates. Overdue risks, risks exceeding tolerance, stalled remediation, or material increases in exposure shall be escalated according to defined thresholds and governance authority.

11. Continuous Monitoring and Reassessment

Cybersecurity risks shall be periodically reviewed and reassessed based on:

- Changes in threat or vulnerability exposure
- Changes in control effectiveness
- Remediation progress or missed target dates

- Significant system, architecture, supplier, or business changes
- New incidents, findings, or regulatory/contractual requirements
- Risk acceptance expiration or scheduled review dates

12. Risk Reporting and Metrics

Cybersecurity / GRC shall provide risk information to appropriate stakeholders and leadership at an established cadence. Reporting shall be risk-based and may include:

- Risk distribution by severity and category
- Residual risk exposure and risks exceeding tolerance
- Overdue remediation and risk aging
- Risk acceptance volume and upcoming expirations
- Key Risk Indicators (KRIs) and Key Performance Indicators (KPIs)
- Material changes and emerging risk trends

13. Policy Exceptions

Exceptions to this policy shall be documented, risk-assessed, approved by authorized management, assigned an expiration or review date, and periodically reassessed. Exceptions shall not be used to bypass required risk decisions or approval authority.

14. Compliance and Enforcement

Noncompliance with this policy may result in documented risk, escalation, corrective action, or other action consistent with organizational governance requirements.

15. Policy Review and Maintenance

This policy shall be reviewed at least annually and when significant changes occur to the organization's risk environment, business operations, technology, governance model, or applicable legal, regulatory, or contractual requirements.

16. Related Frameworks and Supporting Artifacts

This policy is informed by the following risk and security governance frameworks:

- NIST Cybersecurity Framework (CSF)
- NIST SP 800-30
- NIST SP 800-53
- ISO/IEC 27001
- ISO/IEC 27005

Supporting program artifacts include:

- Current-State Cyber Risk Assessment
- Cyber Risk Governance RACI
- Risk Appetite & Tolerance Criteria
- Enterprise Cyber Risk Taxonomy
- Risk Scoring Methodology and 5x5 Risk Matrix
- Enterprise Cyber Risk Register
- Risk Treatment & Acceptance Workflow
- Remediation Tracker
- KPI/KRI Framework and Executive Risk Dashboard

17. Version History

Policy Owner	Cybersecurity / GRC	Version	1.0
Approved By	Executive Leadership	Classification	Internal
Effective Date	7/16/2025	Review Cycle	Annual
Document Status	Portfolio Demonstration	Last Review	7/16/2026

Portfolio Notice: This policy is a simulated portfolio artifact. All organizational details, roles, systems, risks, and data are fictional or sanitized.